

Các dấu hiệu bất thường trong email

- Tạo cảm giác khẩn cấp (Sense of Urgency): Tiêu đề chứa từ "*Khẩn cấp*" nhằm gây tâm lý hoang mang, hối thúc nạn nhân hành động ngay lập tức mà không kịp suy nghĩ hay kiểm tra lại.
- Người gửi lạ: Email đến từ một địa chỉ không quen thuộc hoặc không thuộc tên miền chính thức của công ty (ví dụ: support@security-update-company.com thay vì tên miền nội bộ @company.com).
- Yêu cầu nhấp vào liên kết lạ: Các thông báo bảo mật hợp pháp của hệ thống nội bộ hiếm khi bắt người dùng nhấp trực tiếp vào đường dẫn lạ trong email để cập nhật thông tin cá nhân/tài khoản.
- Nội dung chung chung, thiếu cá nhân hóa: Email phishing thường dùng các lời chào chung như "Kính gửi nhân viên", "Dear Customer" thay vì xưng đích danh tên của nạn nhân.

Các bước nhân viên nên xử lý

1. Không tương tác với email:

Tuyệt đối không nhấp vào liên kết, không tải/mở bất kỳ file đính kèm nào và không phản hồi (reply) lại email này.

2. Kiểm tra độ tin cậy địa chỉ email & đường dẫn:

Rê chuột (hover) qua địa chỉ người gửi và đường dẫn trong email (không nhấp chuột) để kiểm tra URL thực sự bên dưới xem có khớp với hệ thống của công ty hay không.

3. Báo cáo cho bộ phận An toàn thông tin / IT:

Sử dụng nút *Report Phishing* trên trình duyệt email (nếu có) hoặc chuyển tiếp (forward) email đó cho bộ phận CNTT/Security của công ty để họ kiểm tra và chặn người gửi trên toàn hệ thống.

4. Xác minh qua kênh chính thức:

Nếu vẫn nghi ngờ thông báo là thật, hãy liên hệ trực tiếp với bộ phận IT hoặc quản trị viên hệ thống qua kênh nội bộ (Slack, Teams, điện thoại trực tiếp) để xác nhận.

5. Xóa email lừa đảo:

Sau khi đã báo cáo cho bộ phận IT, tiến hành xóa vĩnh viễn email khỏi hộp thư.